

LEY MARCO DE CIBERSEGURIDAD N°21.663

Notificación de Incidente de Ciberseguridad

Organización	Laboratorio Clínico ACLIN Ltda.
RUT Organización	79.749.170-5
Dirección	9 Norte N°795, Viña del Mar, Región de Valparaíso
Fecha del incidente	14 / 10 / 2025 — 10:00 hrs.
Fecha de notificación	17 / 10 / 2025 (dentro del plazo legal de 24 h)
Clasificación	CRÍTICO — Datos sensibles de salud de ~21.000 pacientes expuestos
CISO / Contacto responsable	Paulina Tapia Hernández · seguridad@aclin.cl · +56 9 7452 7614
Auditor Externo	Jaime Gómez Ayala · RUT 16.302.178-1

Clasificación: Confidencial — Jaime Gómez Ayala — Auditor

INCIDENTE CRÍTICO ACTIVO — INC-2025-003 | Vulnerabilidad IDOR explotada — ~21.000 exámenes médicos expuestos | Extorsión \$1.000 USD Bitcoin | Reportado al CSIRT Nacional 17/10/2025

1. DESCRIPCIÓN DEL INCIDENTE

Campo	Detalle
¿Qué ocurrió?	Vulnerabilidad IDOR (Insecure Direct Object Reference) explotada en el portal de pacientes pacientes.aclin.cl. Un actor malicioso aprovechó la falta de validación de autorización en el endpoint /resultados/Pacientes/verexámenes.asp?id_cliente= para acceder masivamente a exámenes médicos mediante un script automatizado.
¿Cuándo?	Detección: 14/10/2025 a las 10:00 hrs. Período de actividad maliciosa: 25/03/2025 al 14/10/2025.
¿Dónde?	Portal web: pacientes.aclin.cl (Microsoft IIS 10.0, Windows Server, SQL Server 2019 puerto 1122). Endpoint: /resultados/Pacientes/verexámenes.asp
Extorsión	El actor malicioso exigió USD \$1.000 en Bitcoin bajo amenaza de publicar los 21.000 registros médicos.

2. IMPACTO ESTIMADO

Dimensión	Evaluación
Información comprometida	Datos de pacientes · Registros médicos · PII · Resultados de exámenes clínicos en PDF
Registros afectados	~21.000 exámenes médicos de pacientes (estimación del actor; confirmada por análisis forense NIVEL4)
Confidencialidad	COMPROMETIDA — Acceso no autorizado masivo a datos de salud sensibles
Integridad	No afectada — Ataque de lectura/extracción exclusivamente
Disponibilidad	No afectada — Servicio continuó operativo durante el período

3. ACCIONES INMEDIATAS TOMADAS

- Activación inmediata del Procedimiento de Gestión de Incidentes.
- Contención: restricción de acceso al endpoint vulnerable.
- Recopilación de evidencia: logs IIS 10.0 (C:\inetpub\logs\LogFiles\W3SVC4).
- Cierre de puerto MSSQL 1122 expuesto a Internet.
- Contacto e inicio de análisis forense por NIVEL4 Forensics.
- Notificación formal al CSIRT Nacional (INC-2025-003) — 17/10/2025.
- Backup y preservación de evidencia digital.
- Comunicación directa con pacientes afectados — pendiente evaluación legal.

4. CRONOLOGÍA DE EVENTOS

Fecha / Hora	Evento	Acción tomada
14/10/2025 – 10:00	Recepción comunicación extorsiva. Detección del incidente IDOR.	Activación del Procedimiento de Gestión de Incidentes. Notificación al CISO y Auditor Externo.
14/10/2025 – 11:30	Análisis preliminar: confirmación de vulnerabilidad IDOR en endpoint.	Contención: restricción acceso al endpoint. Inicio recopilación de logs IIS y SQL Server.
14/10/2025 – 14:00	Cierre de puerto MSSQL 1122 expuesto a Internet.	Aislamiento del endpoint. Contacto con NIVEL4 Forensics para análisis especializado.
15/10/2025 – 09:00	Inicio análisis forense NIVEL4. Estimación: ~21.000 exámenes afectados.	Preservación de evidencia digital. Revisión logs 25/03/2025–14/10/2025.
17/10/2025	Notificación formal al CSIRT Nacional — dentro del plazo legal 24 h (Art. 23 Ley 21.663).	Envío INC-2025-003. Confirmación de recepción por el organismo regulador.
31/10/2025	Remediación completa verificada.	Corrección IDOR, HTTPS/TLS 1.3, cierre de puertos, headers de seguridad HTTP, reCAPTCHA. Incidente cerrado.

5. ANÁLISIS TÉCNICO

Causa raíz: Vulnerabilidad IDOR en el endpoint /resultados/Pacientes/verexámenes.asp?id_cliente=. El sistema no validaba si el usuario autenticado tenía permisos para el id_cliente solicitado (valor codificado en Base64), permitiendo al atacante iterar los identificadores y descargar masivamente exámenes médicos en PDF.

Evidencia técnica	Detalle
Informe Forense	NIVEL4 Forensics v1.0 (17/10/2025)
Logs IIS 10.0	C:\inetpub\logs\LogFiles\W3SVC4 — período 25/03/2025–14/10/2025
Solicitudes maliciosas	1.115 solicitudes totales al recurso /resultados/PACIENTES/PDF/
IPs maliciosas confirmadas	52.34.76.65 · 54.71.187.124 — 438 solicitudes combinadas
Referencia CSIRT	Reporte INC-2025-003 enviado el 17/10/2025

6. PLAN DE REMEDIACIÓN

Acción	Plazo	Responsable
Corregir IDOR: validación de autorización por sesión en verexámenes.asp	31/10/2025	CISO / TI
Implementar reCAPTCHA en portal de pacientes	31/10/2025	CISO / TI
Cerrar puerto MSSQL 1122; implementar HTTPS/TLS; configurar headers HTTP de seguridad	31/10/2025	TI Infraestructura

7. FIRMAS Y APROBACIÓN

CISO / Encargada de Ciberseguridad

Paulina Tapia Hernández
seguridad@aclin.cl

Firma

Representante Legal / CEO – ACLIN Ltda.

Marcelo Tapia Carrere

Firma

Fecha de aprobación: 17 / 10 / 2025